Softwaresikkerhed – Eksamensprojekt

Professionsbacheloruddannelsen i it-sikkerhed – Efteråret 2026

Dette dokument beskriver rammerne og de faglige krav til eksamensprojektet i faget Softwaresikkerhed (10 ECTS).

1 FORMÅL MED PROJEKTET

Formålet med eksamensprojektet er at arbejde praksisnært med fagets metoder, teorier og teknikker på en konkret softwareapplikation.

Projektet skal omfatte en analyse af applikationens sikkerhed, identifikation og prioritering af relevante sikkerhedsproblemer samt implementering og verifikation af udvalgte sikkerhedsforbedringer.

Arbejdet skal resultere i konkrete faglige artefakter, herunder brugstilfælde, misbrugstilfælde, risikovurderinger, trusselsmodeller, kildekode, tests og øvrig relevant dokumentation.

Artefakterne danner et praktisk grundlag for den mundtlige eksamen, hvor den studerende skal kunne anvende fagets teori og metoder til at forklare, begrunde og reflektere over projektets analyser og løsninger.

Projektet er ikke en selvstændig skriftlig eksamensbesvarelse, men skal give de studerende konkrete erfaringer og eksempler, som kan inddrages ved den mundtlige prøve.

2 PROBLEMFORMULERING

Eksamensprojektet tager udgangspunkt i en konkret analyse og forbedring af softwaresikkerheden i WebGoat.NET.

Problemformuleringen og de tilhørende underspørgsmål skal fungere som en fælles ramme for projektarbejdet og understøtte en systematisk tilgang til identifikation, prioritering og håndtering af sikkerhedsproblemer. Projektgruppen skal på den baggrund træffe fagligt begrundede valg om projektets afgrænsning og de sikkerhedsforbedringer, der arbejdes videre med.

2.1 HOVEDSPØRGSMÅL

Hvordan kan sandsynligheden for misbrug af WebGoat.NET reduceres inden for en projektperiode på tre uger?

2.2 UNDERSPØRGSMÅL

1. Hvilke centrale brugstilfælde kan identificeres i WebGoat.NET?
2. Hvordan kan de identificerede brugstilfælde misbruges?
3. Hvilke misbrugstilfælde bør prioriteres på baggrund af en risikovurdering?
4. Hvordan kan sandsynligheden for de prioriterede misbrugstilfælde reduceres gennem forbedringer af applikationens implementering?

2.3 PROJEKTETS TIDSMÆSSIGE RAMMER OG AFGRÆNSNING

Projektperioden strækker sig over tre uger, hvor de studerende sideløbende har undervisning og eksamener i andre fag.

Den forventede arbejdsbelastning til projektet svarer til cirka en tredjedel af en fuldtidsstudieuge på 42 timer. Det svarer til gennemsnitligt 14 timer om ugen og dermed cirka 42 timers projektarbejde pr. studerende i løbet af de tre uger.

Det forventes derfor, at projektgruppen afgrænser analysen og de efterfølgende sikkerhedsforbedringer til et realistisk omfang inden for den tilgængelige tid.

Afgrænsningen skal være fagligt begrundet og risikobaseret, så projektgruppen prioriterer de mest relevante sikkerhedsproblemer.

Det centrale er kvaliteten af de faglige valg og sammenhængen mellem analyse, prioritering, implementering og verifikation frem for omfanget af de gennemførte aktiviteter.

3 PROJEKTARBEJDE OG INDIVIDUEL EKSAMEN

Projektarbejdet gennemføres i grupper, mens den mundtlige eksamen er individuel.

Projektgruppen udarbejder i fællesskab projektets analyser, implementeringer og øvrige artefakter.

Ved den mundtlige eksamen skal den enkelte studerende kunne anvende og redegøre for relevante dele af projektarbejdet. Det forventes, at den studerende har et overordnet kendskab til hele projektet og kan forklare sammenhængen mellem projektets artefakter, også når disse er udarbejdet af andre medlemmer af projektgruppen.

Bedømmelsen tager udgangspunkt i den enkelte studerendes egen faglige præstation og opfyldelse af fagets læringsmål.

3.1 FAGLIGE KRAV TIL PROJEKTET

Projektet tager udgangspunkt i den applikation, der er beskrevet i afsnittet *Den analyserede applikation*.

Analysen og de valgte sikkerhedsforbedringer skal primært baseres på metoder og teorier fra faget Softwaresikkerhed.

Relevante emner fra andre fag, f.eks. Webapplikationssikkerhed, Introduktion til IT-sikkerhed og Sikkerhed i IT-governance, kan inddrages, hvor det er fagligt relevant, men emner fra faget Softwaresikkerhed vægtes højst.

Projektet skal omfatte:

- En metodisk analyse af applikationens sikkerhed.
- Identifikation og prioritering af relevante sikkerhedsproblemer.
- Trusselsmodellering af udvalgte sikkerhedsproblemer.
- Implementering af relevante sikkerhedsforbedringer.
- Test og verifikation af de implementerede forbedringer.
- Dokumentation gennem relevante artefakter og kildekode.

Det forventes ikke, at alle dele af applikationen undersøges, eller at alle identificerede sikkerhedsproblemer afhjælpes.

Projektet skal afgrænses, prioriteres og kvalificeres på et fagligt begrundet og risikobaseret grundlag.

Husk, at metodebeskrivelser, krav og faglige begreber kan fortolkes forskelligt. Brug derfor vejledningen til at få afklaret jeres forståelse og faglige valg tidligt i projektperioden.

4 METODEKRAV

Projektet skal tage udgangspunkt i fagets overordnede metode, som anvendes pragmatisk og risikobaseret.

I metoden opstilles **systemmål som brugstilfælde**, mens **sikkerhedsmål opstilles som misbrugstilfælde**.

Brugstilfældene beskriver den værdi og funktionalitet, systemet skal levere til sine aktører. Misbrugstilfældene beskriver, hvordan denne værdi, funktionalitet eller tilhørende aktiver kan kompromitteres.

I den efterfølgende projektbeskrivelse anvendes betegnelserne *brugstilfælde* og *misbrugstilfælde* om disse artefakter.

Den overordnede metode omfatter seks trin:

Brugstilfælde → Misbrugstilfælde → Risikovurdering → Trusselsmodellering → Implementering af sikkerhedsforbedringer → Verifikation

1. Brugstilfælde

Der skal skabes en forståelse af applikationens kontekst, centrale formål og funktionalitet.

Relevante brugstilfælde skal identificeres og beskrives med udgangspunkt i den værdi, som applikationen leverer til sine aktører. Brugstilfælde skal beskrives på et overordnet forretningsniveau og i et sprog, der kan forstås på tværs af faggrupper.

Der skal identificeres relevante aktører og aktiver, som er nødvendige for at forstå applikationens sikkerhedsbehov.

2. Misbrugstilfælde

På baggrund af brugstilfældene skal relevante misbrugstilfælde identificeres.

Misbrugstilfældene skal beskrive, hvordan brugstilfældene kan kompromitteres.

CIA-modellen anvendes som støtte til systematisk at undersøge mulige brud på fortrolighed, integritet og tilgængelighed.

Misbrugstilfældene skal beskrives på et overordnet forretningsniveau og i et sprog, der kan forstås på tværs af faggrupper.

Der skal være en tydelig sammenhæng mellem misbrugstilfældene og de brugstilfælde eller aktiver, de potentielt kompromitterer.

3. Risikovurdering

De identificerede misbrugstilfælde skal risikovurderes med henblik på at prioritere det videre sikkerhedsarbejde.

Risikovurderingen skal dokumentere:

- Anvendte skalaer for sandsynlighed og konsekvens, herunder definitionen af skalaernes værdier.

- En risikomatrix eller tilsvarende vurderingsmodel.
- Risikovurderinger af de identificerede misbrugstilfælde.
- Faglige begrundelser for vurderingerne.
- Prioritering af de misbrugstilfælde, der skal analyseres nærmere.

Der skal tages stilling til eventuel usikkerhed, antagelser og manglende viden.

Formålet er ikke nødvendigvis at opnå præcise risikoværdier, men at skabe et kvalificeret grundlag for prioritering.

Tilgangen tager udgangspunkt i fagets pragmatiske anvendelse af risikovurdering, inspireret af ISO/IEC 27005:2022.

Det forventes ikke, at alle identificerede misbrugstilfælde analyseres videre i samme detaljeringsgrad.

4. Trusselsmodellering

Udvalgte og prioriterede misbrugstilfælde skal analyseres på et teknisk niveau gennem trusselsmodellering.

Der skal udarbejdes relevante arkitekturdiagrammer over de dele af applikationen, som indgår i analysen.

Diagrammerne skal vise relevante komponenter, interaktioner og tillidsgrænser.

STRIDE skal anvendes til systematisk identifikation og kategorisering af tekniske trusler.

Trusselsmodelleringen skal have en tydelig sammenhæng med de prioriterede misbrugstilfælde og må ikke alene bestå af en generel liste over mulige tekniske angreb.

Det forventes ikke, at hele applikationens arkitektur modelleres i detaljer, eller at alle tænkelige tekniske trusler identificeres.

5. Implementering af sikkerhedsforbedringer

På baggrund af den gennemførte analyse skal der udvælges og implementeres relevante sikkerhedsforbedringer i applikationen.

Forbedringerne skal kunne begrundes med udgangspunkt i de identificerede og prioriterede risici og tekniske trusler.

Implementeringerne kan f.eks. tage udgangspunkt i fagets kodepraksis og principper fra *Secure by Design (Bergh Johnsson et al., 2019)*, herunder domæneprimitiver, inputvalidering, objektinvarians, sikker fejlhåndtering og andre relevante design- og programmeringsteknikker.

Der kan desuden arbejdes med forbedringer af udviklingsprocessen, f.eks. automatiserede tests og sikkerhedskontroller i en CI/CD-pipeline.

Både forbedringer i programkode og automatiserede sikkerhedskontroller er relevante, men de demonstrerer forskellige sikkerhedsfaglige færdigheder.

De valgte forbedringer skal kunne forklares og begrundes i forhold til deres formål, implementering og sikkerhedsmæssige virkning.

Det centrale er sammenhængen mellem analysen og de implementerede forbedringer, ikke antallet af implementeringer.

6. Verifikation

De implementerede sikkerhedsforbedringer skal verificeres med relevante metoder.

Verifikation kan f.eks. omfatte test af implementeringens funktion og sikkerhedsegenskaber samt verifikation mod relevante sikkerhedskrav fra en anerkendt standard, f.eks. OWASP Application Security Verification Standard (ASVS).

Valget af verifikationsmetode skal kunne begrundes, og det skal fremgå, hvordan verifikationen er gennemført, og hvad resultaterne dokumenterer.

Der skal desuden kunne redegøres for verifikationens begrænsninger, herunder hvad der ikke er blevet undersøgt.

Formålet er ikke at anvende flest mulige verifikationsmetoder, men at kunne underbygge, at de valgte sikkerhedsforbedringer fungerer efter hensigten.

4.1 SAMMENHÆNG OG SPORBARHED I METODEN

Det er et **centralt krav, at metoden anvendes sammenhængende**.

Projektet skal ikke blot resultere i en række isolerede artefakter, men demonstrere en faglig sammenhæng fra brugstilfælde og misbrugstilfælde til risikovurdering og trusselsmodellering og videre til implementering og verifikation.

Et prioriteret misbrugstilfælde bør således kunne følges gennem analysen til de identificerede tekniske trusler, valgte sikkerhedsforbedringer og den efterfølgende verifikation.

Det skal være muligt at forklare, hvorfor et sikkerhedsproblem er relevant, hvordan det er blevet prioriteret, hvilke tekniske trusler der er identificeret, og hvordan de implementerede forbedringer adresserer problemet.

Det forventes ikke, at alle identificerede risici og trusler håndteres gennem implementering.

4.2 RESTERENDE RISICI OG BEGRUNDEDE FRAVALG

Der skal kunne redegøres for væsentlige identificerede risici og trusler, som ikke er blevet håndteret gennem projektets implementeringer.

Fravalg bør begrundes med udgangspunkt i risikovurderingen, projektets afgrænsning, tekniske begrænsninger og tilgængelige ressourcer.

Det er vigtigt at skelne mellem en risiko, som projektgruppen har valgt ikke at arbejde videre med, og en risiko, som formelt er accepteret af den ansvarlige risikoejer.

Et fravalg i projektarbejdet er således ikke nødvendigvis ensbetydende med, at risikoen er acceptabel for den organisation, der anvender systemet.

4.3 VEJLEDENDE ANVENDELSE AF METODER OG TEORIER

Ud over den overordnede metode skal projektet inddrage relevante metoder, teorier og teknikker fra undervisningen.

Ved design og implementering kan der f.eks. anvendes principper fra *Secure by Design* (Bergh Johnsson et al., 2019), herunder domænemodellering, domæneprimitiver, inputvalidering, objektinvarians og sikker fejlhåndtering.

Til analyse og kvalitetssikring kan der f.eks. anvendes statisk kodeanalyse, scanning af tredjepartsafhængigheder og andre relevante metoder og værktøjer fra undervisningen.

Resultater fra automatiserede analyseværktøjer skal vurderes fagligt. Et værktøjsfund er ikke i sig selv dokumentation for en reel sårbarhed, ligesom fravær af fund ikke dokumenterer, at applikationen er sikker.

Hvor det er relevant, kan sikkerhedsforbedringer kobles til konkrete sikkerhedskrav fra eksempelvis OWASP ASVS 5.0.0.

4.4 ARTEFAKTER OG DOKUMENTATION

Projektarbejdet skal resultere i konkrete artefakter, som dokumenterer analyser, faglige valg, implementeringer og verifikation.

Artefakterne skal være tilgængelige ved den mundtlige eksamen.

Forventede artefakter

Område	**Relevante artefakter**
Brugstilfælde	Brugstilfælde og tilhørende beskrivelser, eventuelt suppleret med et brugstilfældediagram.
Misbrugstilfælde	Identificerede og beskrevne misbrugstilfælde samt sammenhæng til brugstilfælde
Risikovurdering	Skalaer, risikomatrix, vurderinger, begrundelser og prioriteringer
Trusselsmodellering	Arkitekturdiagrammer, tillidsgrænser, STRIDE-analyser og identificerede tekniske trusler
Implementering	Kildekode, kodeændringer, konfiguration og implementerede sikkerhedsforbedringer
Verifikation	Testkode, testresultater og anden dokumentation af gennemført verifikation
Øvrige artefakter	F.eks. domænemodeller, designbeslutninger, analyser og CI/CD-konfiguration

Tabellen beskriver de centrale typer af artefakter og giver eksempler på deres indhold, men er ikke udtømmende.

Det forventes ikke, at samtlige mulige artefakter eller teknikker anvendes. Artefakterne skal være relevante for projektets analyse, prioriteringer og implementeringer.

4.4.1 Organisering af artefakter

Projektets artefakter skal placeres i eller være tilgængelige gennem projektgruppens kildekoderepository, f.eks. GitHub eller GitLab.

Repositoryet skal indeholde relevant kildekode, dokumentation, tests og eventuel CI/CD-konfiguration.

Materialet skal organiseres, så det er muligt at forstå projektets faglige valg og sammenhængen mellem metodens trin.

Hvis det på grund af tekniske eller praktiske begrænsninger ikke er muligt at ændre direkte i applikationens kildekode, kan der udarbejdes et selvstændigt proof of concept, der demonstrerer den foreslåede løsning.

Hvor det er praktisk muligt, foretrækkes implementering direkte i den analyserede applikation.

4.4.2 Fremvisning af artefakter ved eksamen

Den studerende skal under den mundtlige eksamen kunne fremvise og redegøre for relevante artefakter fra projektarbejdet.

Det forventes, at den studerende har et overordnet kendskab til hele projektet og kan forklare sammenhængen mellem de udarbejdede artefakter.

Den studerende behøver ikke selv at have udarbejdet alle artefakter, men skal kunne anvende relevante dele af projektarbejdet til at demonstrere sin egen faglige forståelse.

Det er ikke nødvendigt at gennemgå samtlige artefakter under den indledende præsentation. Alle udarbejdede artefakter skal dog være tilgængelige, så eksaminator og censor kan bede om at få dem fremvist.

4.4.3 Projektarbejdets betydning for bedømmelsen

Projektarbejdet udgør et væsentligt praktisk grundlag for den mundtlige eksamen.

Fagets læringsmål omfatter både viden, færdigheder og kompetencer. Særligt færdigheds- og kompetencemålene forudsætter, at den studerende kan demonstrere praktisk anvendelse af fagets metoder, teknikker og principper.

Den studerende forventes derfor at inddrage og fremvise projektarbejde med tilhørende artefakter under eksaminationen.

Hvis den studerende ikke anvender eller kan fremvise projektarbejde med tilhørende artefakter, vil det væsentligt begrænse grundlaget for at afprøve og bedømme den praktiske opfyldelse af fagets færdigheds- og kompetencemål.

Et velfungerende gruppeprojekt er ikke i sig selv dokumentation for, at den enkelte studerende opfylder læringsmålene. Tilsvarende udelukker mangler i projektet ikke, at den studerende kan demonstrere relevant faglig forståelse gennem forklaringer, begrundelser og refleksioner.

Bedømmelsen foretages på baggrund af den studerendes samlede individuelle præstation.

5 DEN ANALYSEREDE APPLIKATION

Projektet tager udgangspunkt i følgende applikation:

WebGoat.NET

https://github.com/mesn1985/Software-sikkerhed-eksamen-e26

Som udgangspunkt bør hver projektgruppe oprette sit eget repository, som alle i projektgruppen har adgang til.

Repositoryet anvendes til projektets analyser, dokumentation, kildekode, tests og øvrige artefakter.

5.1 FORSTÅELSE OG AFGRÆNSNING AF APPLIKATIONEN

Den udleverede applikation udgør projektets fælles analyse- og udviklingsgrundlag.

Projektarbejdet skal tage udgangspunkt i en undersøgelse af applikationens eksisterende funktionalitet, arkitektur og sikkerhedsmæssige forhold.

Eventuelle tekniske begrænsninger, eksisterende sårbarheder og uhensigtsmæssige designvalg skal indgå i de faglige vurderinger.

Det forventes ikke, at alle identificerede sikkerhedsproblemer afhjælpes. Projektets afgrænsning og prioriteringer skal derimod kunne begrundes med udgangspunkt i fagets metode.

6 VEJLEDNING UNDER PROJEKTPERIODEN

Der er afsat specifikke dage til vejledning i løbet af projektperioden.

Vejledningen kan anvendes til at drøfte projektets afgrænsning, brugstilfælde, misbrugstilfælde, risikovurdering, trusselsmodellering, implementering, verifikation og den metodiske sammenhæng mellem projektets artefakter.

Det anbefales at benytte vejledningen tidligt i projektperioden, da beslutninger om afgrænsning og analyse har betydning for det efterfølgende arbejde.

Som udgangspunkt tilbydes vejledning på de planlagte vejledningsdage. Der kan ikke forventes individuel vejledning uden for disse tidspunkter, medmindre andet er aftalt med underviseren.

Projektgruppen har ansvar for at forberede konkrete spørgsmål og relevant materiale til vejledningen.

7 EKSAMENSBESKRIVELSE OG STRUKTUR

Eksamen gennemføres i henhold til prøvebeskrivelsen i den institutionelle studieordning.

Prøven er individuel, mundtlig og varer 25 minutter inklusive votering.

Ved eksamen trækker den studerende ét af de tre offentliggjorte eksamensspørgsmål.

Der er ingen forberedelsestid efter trækningen. Den studerende forventes derfor at være forberedt på alle tre spørgsmål.

Eksamensspørgsmålene offentliggøres senest 14 dage før eksamen.

Eksamensforløb

Tid	**Aktivitet**
0–5 minutter	Præsentation af projektets metodiske arbejde
5–10 minutter	Besvarelse af det udtrukne eksamensspørgsmål
10–15 minutter	Demonstration af en implementeret sikkerhedsforbedring
15–20 minutter	Uddybende spørgsmål fra eksaminator og censor
20–25 minutter	Votering

Tidsangivelserne er omtrentlige.

1. Præsentation af projektets metodiske arbejde – ca. 5 minutter

Den studerende skal præsentere, hvordan der gennem projektarbejdet er arbejdet metodisk med at analysere og forbedre sikkerheden i den udleverede applikation.

Præsentationen skal tage udgangspunkt i fagets overordnede metode:

Brugstilfælde → Misbrugstilfælde → Risikovurdering → Trusselsmodellering → Implementering → Verifikation

Med udgangspunkt i relevante artefakter fra projektarbejdet skal den studerende vise, hvordan metodens forskellige trin er anvendt, hvilke faglige valg og prioriteringer der er foretaget, og hvordan resultaterne fra de enkelte trin har dannet grundlag for det videre arbejde.

Det anbefales at anvende konkrete eksempler fra projektet til at illustrere sammenhængen mellem analyse, implementering og verifikation.

Formålet er ikke at gennemgå samtlige artefakter eller give en generel teoretisk redegørelse for metoden, men at demonstrere, hvordan den er anvendt sammenhængende og systematisk gennem projektarbejdet.

2. Besvarelse af det udtrukne eksamensspørgsmål – ca. 5 minutter

Den studerende skal besvare det udtrukne eksamensspørgsmål med udgangspunkt i relevante teorier, metoder og principper fra faget.

Besvarelsen bør omfatte forklaring af relevante faglige begreber, anvendelse af metoder, konkrete eksempler fra projektarbejdet samt faglige begrundelser og refleksioner.

Det forventes ikke, at alle aspekter af et bredt fagligt emne behandles udtømmende på fem minutter.

Der lægges vægt på en relevant og fagligt velbegrundet besvarelse.

Den studerende kan med fordel forberede en kort præsentation med konkrete eksempler fra projektarbejdet.

3. Demonstration af en implementeret sikkerhedsforbedring – ca. 5 minutter

Den studerende skal demonstrere en konkret sikkerhedsforbedring, som er implementeret i forbindelse med projektarbejdet.

Demonstrationen kan f.eks. tage udgangspunkt i programkode, et domæneprimitiv, inputvalidering, sikker fejlhåndtering eller en sikkerhedskontrol i en CI/CD-pipeline.

Den studerende skal kunne:

1. Forklare, hvilket sikkerhedsproblem forbedringen adresserer.
2. Begrunde, hvorfor forbedringen er valgt.
3. Fremvise og forklare den konkrete implementering.
4. Demonstrere, hvordan det er verificeret, at forbedringen fungerer efter hensigten.

Demonstrationen skal omfatte mere end en gennemgang af kildekode eller konfiguration.

Den studerende skal kunne forklare, hvad demonstrationen dokumenterer, og hvilke begrænsninger der er ved den valgte verifikation.

Praktisk forberedelse af demonstrationen

Det anbefales, at demonstrationen forberedes, så den kan gennemføres inden for den afsatte tid.

Relevant kildekode, tests, konfiguration og øvrige artefakter bør være umiddelbart tilgængelige.

Hvis demonstrationen afhænger af eksterne tjenester, eksempelvis GitHub Actions, anbefales det at have dokumentation fra tidligere gennemførsler tilgængelig som alternativ ved eventuelle tekniske problemer på eksamenstidspunktet.

Dette kan f.eks. være testresultater, logudskrifter eller resultater fra automatiserede sikkerhedskontroller.

Den studerende skal fortsat kunne forklare implementeringen og betydningen af de fremviste resultater.

4. Uddybende eksamination – ca. 5 minutter

De efterfølgende ca. fem minutter anvendes til spørgsmål fra eksaminator og censor.

Spørgsmålene kan tage udgangspunkt i det udtrukne eksamensspørgsmål, præsentationen, demonstrationen, projektets øvrige artefakter samt relevante teorier og metoder fra faget.

Den studerende skal kunne fremvise yderligere artefakter efter anmodning.

Der kan stilles spørgsmål til projektets samlede metode og faglige valg for at undersøge den enkelte studerendes selvstændige forståelse.

5. Votering – ca. 5 minutter

De resterende ca. fem minutter anvendes til votering.

Prøven bedømmes efter 7-trinsskalaen med ekstern bedømmelse.

Bedømmelsen er en helhedsvurdering af den studerendes opfyldelse af fagets læringsmål, herunder faglig forståelse, metodeanvendelse, analyse, argumentation, implementering, verifikation og refleksion.

7.1 Anbefaling om sammenhæng mellem eksamensdelene

Det anbefales kraftigt, at den studerende tilrettelægger eksamen, så der skabes en tydelig faglig sammenhæng mellem præsentationen af projektets metodiske arbejde, besvarelsen af det udtrukne eksamensspørgsmål og demonstrationen af en implementeret sikkerhedsforbedring.

Det anbefales særligt, at den demonstrerede forbedring kan relateres til et prioriteret misbrugstilfælde, den tilhørende risikovurdering og identificerede tekniske trusler.

Hvor det er fagligt relevant, bør det udtrukne eksamensspørgsmål også inddrages i denne sammenhæng.

Det er dog **ikke et krav, at alle tre eksamensdele omhandler præcis det samme sikkerhedsproblem eller den samme implementering**.

Da eksamensspørgsmålet trækkes tilfældigt, vil en direkte sammenhæng ikke altid være naturlig.

Den studerende bedømmes på sin samlede faglige præstation og opfyldelse af læringsmålene.

7.2 EKSAMENSSPØRGSMÅL

1. Sikkerhedsanalyse og risikovurdering

Hvordan kan man identificere, analysere og prioritere sikkerhedsproblemer i en softwareapplikation?

Med udgangspunkt i relevante artefakter fra projektarbejdet skal du forklare og begrunde, hvordan metoder og teorier fra faget kan anvendes til at identificere og vurdere sikkerhedsproblemer samt understøtte risikobaserede beslutninger.

Du skal desuden reflektere over de anvendte metoders styrker, begrænsninger og betydning for arbejdet med softwaresikkerhed.

Eksempler på relevante emner:

- Systemmål og sikkerhedsmål (brugstilfælde og misbrugstilfælde).
- Risikovurdering og prioritering af misbrugstilfælde.
- Trusselsmodellering og anvendelse af STRIDE.
- Sammenhængen mellem forretningsmæssige risici, tekniske trusler og sikkerhedskrav.

2. Secure by Design og sikker kodepraksis

Hvordan kan principper fra Secure by Design og sikker kodepraksis anvendes til at forebygge sårbarheder i software?

Med udgangspunkt i relevante artefakter eller implementeringer fra projektarbejdet skal du forklare, hvordan principper, metoder og programmeringsteknikker fra faget kan anvendes til at understøtte udviklingen af sikker software.

Du skal desuden begrunde relevante design- og implementeringsvalg samt reflektere over deres sikkerhedsmæssige betydning, styrker og begrænsninger.

Eksempler på relevante emner:

- Secure by Design og betydningen af domæneforståelse og domænemodellering.
- Inputvalidering og håndtering af ugyldige data.
- Domæneprimitiver og deres betydning for sikkerhed.
- Sikker fejlhåndtering og håndtering af exceptions.

3. Værktøjer til analyse og forbedring af softwaresikkerhed

Hvordan kan værktøjer anvendes til at identificere og vurdere sårbarheder samt understøtte arbejdet med at forbedre softwaresikkerheden?

Med udgangspunkt i relevante artefakter eller erfaringer fra projektarbejdet skal du forklare, hvordan værktøjer og automatiserede sikkerhedskontroller fra faget kan anvendes til at undersøge og forbedre softwaresikkerheden.

Du skal desuden begrunde valg og anvendelse af relevante værktøjer samt reflektere over deres muligheder, begrænsninger og fortolkningen af deres resultater.

Eksempler på relevante emner:

- Statisk kodeanalyse, herunder taint-analyse.
- Identifikation af sårbarheder i tredjepartsafhængigheder.
- Automatiserede sikkerhedskontroller i CI/CD-pipelines.
- Automatiseret test og verifikation af sikkerhedsegenskaber (unit tests).
- Fortolkning af analyseresultater, herunder falske positiver og begrænsninger ved automatiserede værktøjer.

Bemærkning: Ovenstående emner er vejledende eksempler og ikke en udtømmende liste eller obligatoriske delspørgsmål. Den studerende forventes at udvælge relevante emner, der understøtter besvarelsen af det udtrukne spørgsmål, med udgangspunkt i fagets teori og konkrete artefakter fra projektarbejdet.